

Tool: Automated Governance & Standards Compliance Audit

Target Audience: Enterprise Architects, Solution Architects, Architecture Review Boards (ARBs), Security & Compliance Officers

1. Product Overview & Core Value Proposition

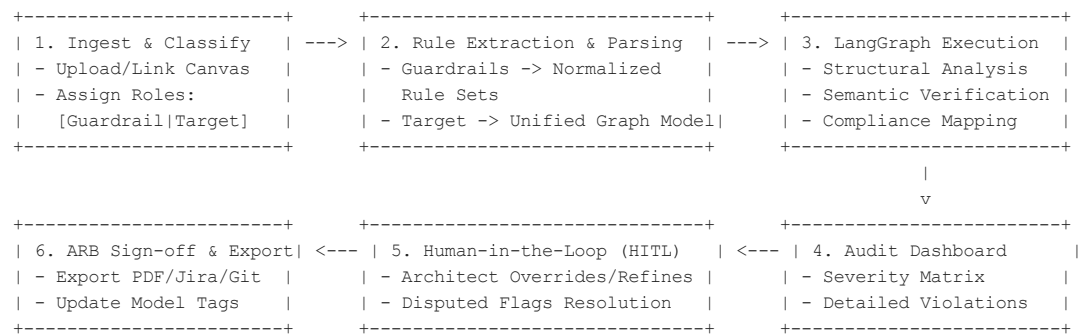
1.1 Objective

The **Automated Governance & Standards Compliance Audit Tool** acts as an intelligent "linter" for enterprise architecture. By ingesting both policy/guardrail documents and target architecture models (such as ArchiMate models, solution architecture documents, or cloud infrastructure designs), the tool automates complex, multi-layered compliance checks prior to formal Architecture Review Board (ARB) meetings.

1.2 Value Proposition

- **Reduce ARB Cycle Time:** Cut manual compliance review time by up to 80%, shifting ARB focus from routine checklist verification to strategic design decisions.
- **Early Defect Detection:** Identify missing encryption layers, single points of failure (SPOFs), unapproved tech stacks, and data residency risks during the design phase rather than during runtime or implementation.
- **Deterministic Policy Enforcement:** Standardize evaluation across disparate solution teams using AI-guided graph workflows that cite exact policy sources.

2. User Journey & Workflow Architecture



2.1 Workflow Steps

1. **Document Selection & Role Assignment:**
 - User adds or links documents into the Canvas context (e.g., PDFs, Word, Markdown, Confluence links, ArchiMate Open Exchange XML/JSON).
 - User explicitly classifies each document as either a **Guardrail Document** (e.g.,

Zero-Trust Policy, Data Protection Act, Cloud-First Rules) or an **Architecture Target Document** (e.g., Solution Architecture Document, ArchiMate Model Export, Infrastructure-as-Code).

2. **Analysis Launch:**

- User clicks **"Run Governance Audit"**, specifying optionally a scoping preset (e.g., *Strict Security Audit*, *GDPR Focus*, *TOGAF Alignment*).

3. **Automated Pipeline Execution:**

- LangGraph agentic workflow parses rules, maps guardrails to design elements, identifies discrepancies, assesses risk severity, and synthesizes findings.

4. **Interactive Audit Dashboard:**

- User explores interactive findings categorized by severity (Critical, Major, Minor, Info), with direct references to model nodes and policy clauses.

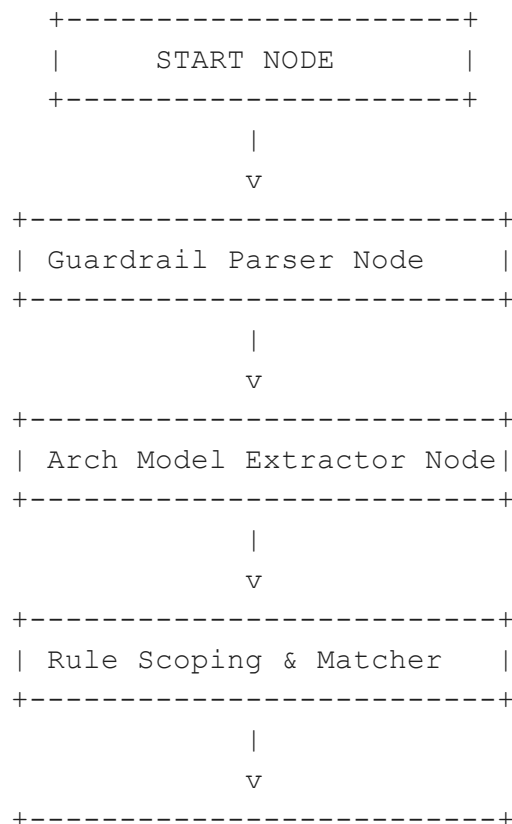
5. **Human-in-the-Loop (HITL) Review:**

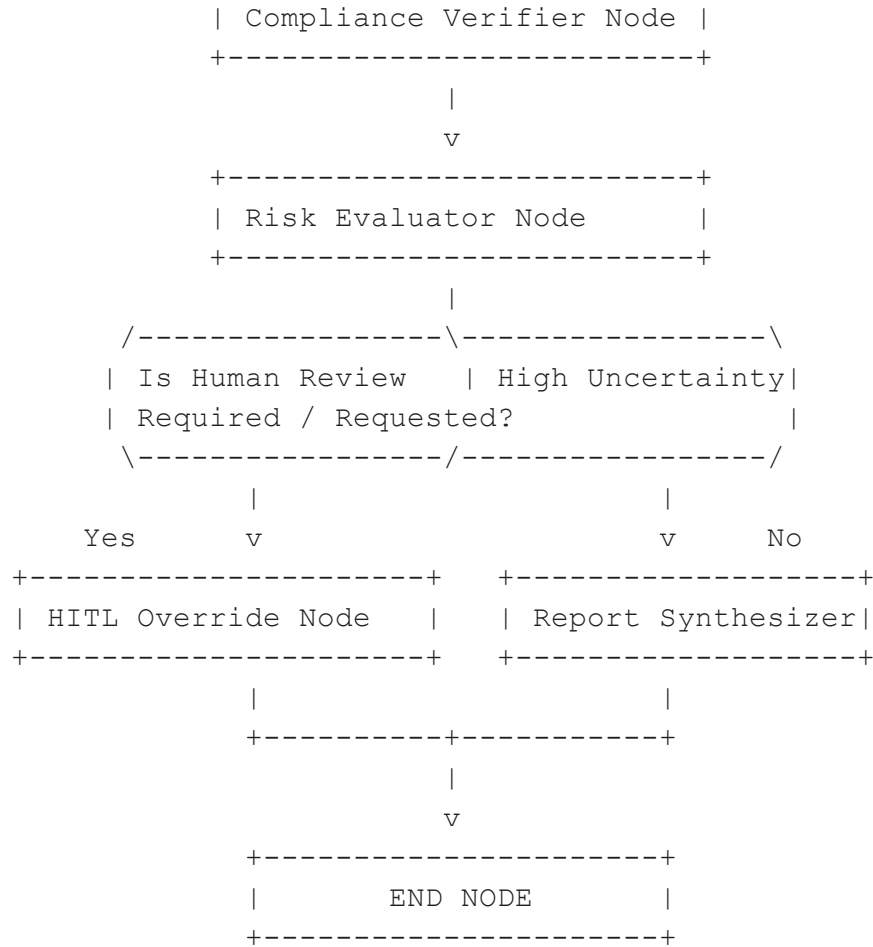
- Architects can approve findings, mark false positives, request mitigation plans, or add contextual waivers.

6. **Report Export & Actionability:**

- Export standardized ARB Briefing documents (PDF, Markdown), push issue tickets to Jira/ServiceNow, or write compliance annotations back to the model.

3.2 LangGraph Node Blueprint





Node Details

1. Guardrail Parser Node

- **Role:** Analyzes Guardrail documents using LLM unstructured-to-structured parsing.
- **Task:** Extracts discrete, testable logic rules from natural text (e.g., "All persistent data stores containing PII must use AES-256 encryption").
- **Output:** Updates parsed_rules array in state.

2. Arch Model Extractor Node

- **Role:** Parses target architecture inputs.
- **Task:** Converts XML ArchiMate models or unstructured Architecture Specs into an internal JSON Graph of Elements, Interfaces, Data Flows, and Hosting Nodes.
- **Output:** Updates parsed_architecture state.

3. Rule Scoping & Matcher Node

- **Role:** Pre-filters and maps parsed rules to relevant architecture elements (reducing token usage and context overhead).
- **Task:** Matches rules about "Data Encryption" only to Data Objects, Storage Nodes, and Data Flows.

4. Compliance Verifier Node

- **Role:** Performs semantic and structural audit evaluations.
- **Task:**
 - *Structural check:* Is there an encryption node between Data Store A and External System B?
 - *Technology Radar check:* Is PostgreSQL v9.6 used despite being deprecated in guardrails?
 - *Topology check:* Does a single API Gateway represent a Single Point of Failure (SPOF)?
- **Output:** Generates raw violations list with evidence citations.

5. Risk Evaluator Node

- **Role:** Calculates compound risk score and assigns final severity based on impact and likelihood.
- **Task:** Weighs violations against context (e.g., an unencrypted internal logging queue is Major, but an unencrypted public API endpoint with PII is Critical).

6. Human-in-the-Loop (HITL) Node *(Conditional Trigger)*

- **Role:** Intercepts low-confidence evaluations or high-criticality flags for human architect verification before final report generation.

7. Report Synthesizer Node

- **Role:** Consolidates findings into an executive summary, scorecards (e.g., 84% Compliance Rating), and clear remediation pathways.

4. Guardrail Catalog & Pre-built Rule Types

The system must support both **Automated Out-of-the-Box Checks** and **Custom Policy Extraction**.

Guardrail Domain	Example Policy / Rule	Detection Logic in ArchiMate / Doc
Zero-Trust & Security	"All data in transit across zone boundaries must use encrypted protocols."	Scans Flow or Triggering relationships between components across different Location / Group boundaries lacking a secure protocol property.
Data Protection / GDPR	"EU Customer PII must not be hosted or processed on non-EU infrastructure."	Identifies DataObject tagged as PII linked via Specialization or Serving to Node elements with Location != EU.

Resilience & Fault Tolerance	"Critical Business Services must not depend on non-redundant single components."	Analyzes graph topology for BusinessService elements with path dependency on a single ApplicationComponent without active-active/standby replication.
Tech Radar / Standardisation	"Unapproved legacy databases (e.g., Oracle 11g) are prohibited for new designs."	Matches Node / SystemSoftware name or property fields against an Enterprise Tech Radar blacklist.
TOGAF / Architecture Principles	"Application components must interact via standard API Interfaces, not direct DB access."	Detects direct Access relationships between ApplicationComponent A and DataObject owned by ApplicationComponent B.

5. Functional Feature Requirements

5.1 Document Ingestion & Classification (Canvas Integration)

- **FR-1.1:** Canvas UI must allow dragging & dropping files (.xml, .json, .pdf, .docx, .md).
- **FR-1.2:** Toggle selection for document role: **[Guardrail Policy]** vs. **[Target Architecture]**.
- **FR-1.3:** Built-in ArchiMate parser supporting the official **Open Group ArchiMate Model Exchange File Format** (XML schema).

5.2 Analysis & Rule Customization

- **FR-2.1:** Scope Selector: Allow user to enable/disable specific rule categories before execution (e.g., Security, Cloud Compliance, Cost Optimization).
- **FR-2.2:** Sensitivity Slider: Adjust rule strictness (Strict, Standard, Tolerant).

5.3 Interactive Compliance Dashboard

- **FR-3.1: Compliance Score Gauge:** Overall metric (0–100%) calculated based on weighted violations.
- **FR-3.2: Filterable Violation List:** Filter by Severity (Critical, Major, Minor), Category, or Architecture Domain (Business, Application, Technology).
- **FR-3.3: Side-by-Side Traceability Inspector:** Clicking a violation highlights:
 1. The exact Guardrail document text snippet & rule.

2. The target ArchiMate element / document paragraph causing the violation.
3. AI-suggested fix / architecture refactoring options.

5.4 Audit Override & Human Feedback (HITL)

- **FR-4.1:** Provide actions on every finding: [Accept Finding], [Mark False Positive], [Grant Exemption / Waiver].
- **FR-4.2:** Require a text rationale whenever an architect grants an exemption.

5.5 Reporting & Integration Export

- **FR-5.1:** Export ARB Executive Summary PDF.
- **FR-5.2:** Export Annotated ArchiMate Model (injecting standard properties into non-compliant components: e.g., `compliance_status = FAILED`).
- **FR-5.3:** Integration push to Jira/ServiceNow (creates actionable stories for engineering teams).

7. Non-Functional Requirements (NFRs)

- **Accuracy & Determinism:** Hallucination rate must be minimized by enforcing ground-truth citations (every finding must directly quote the policy document).
- **Security & Privacy:** Models and guardrails often contain confidential IP; data must be processed in zero-data-retention LLM endpoints with end-to-end encryption.
- **Explainability:** Non-compliance flags must explain the *reasoning path* taken by the LangGraph agent chain.